



Modul 5: Datenschutz & IT-Sicherheit bei KI-Nutzung

Sicherer und datenschutzkonformer Einsatz von KI im Unternehmen

Einführung Datenschutz und KI

Warum Datenschutz bei KI essenziell ist



Verarbeitung sensibler Daten

KI verarbeitet häufig personenbezogene und sensible Daten (z.B. Bewerbungen, Kundenanfragen, biometrische Daten).



Risiken für Unternehmen

Fehler beim Datenschutz gefährden Unternehmen (rechtliche Konsequenzen, Reputationsverlust).



DSGVO-Konformität

DSGVO-Konformität ist bei KI-Nutzung Pflicht – auch bei technisch komplexen Systemen.

Personenbezogene Daten und KI

Welche Daten sind besonders kritisch?

Gesundheitsdaten

Besonders schutzbedürftige
Informationen über den
Gesundheitszustand

Scheinbar harmlose Daten

Auch Logfiles und Bewerbungen fallen
unter Datenschutz



Ethnische Herkunft

Informationen über die ethnische
Zugehörigkeit einer Person

Biometrische Daten

Z.B. Gesichtserkennung und andere
eindeutige körperliche Merkmale

Fotos

Bildmaterial mit identifizierbaren
Personen

Grundprinzip: Personenbezug immer kritisch bewerten.

Verantwortlichkeit und Rechenschaftspflicht

Wer trägt Verantwortung?



Transparenz und Informationspflichten

Wie transparent muss KI sein?



Informationspflicht

Betroffene müssen wissen, wie und wofür ihre Daten genutzt werden (Art. 13/14 DSGVO).



Verständlichkeit

KI-Entscheidungen müssen verständlich erklärt werden – trotz technischer Komplexität.



Rechtssicherheit

Transparente Information ist Voraussetzung für rechtssichere KI-Nutzung.



Automatisierte Entscheidungen (Art. 22 DSGVO)

Wann ist KI-Automatisierung erlaubt?

Vollautomatische Entscheidungen mit rechtlichen Folgen (Kredit, Bewerbungen) sind nur unter Bedingungen erlaubt.

Human in the Loop

Pflicht: Menschliche Prüfung und Bestätigung der KI-Ergebnisse notwendig.

Nutzung externer KI-Dienste (Auftragsverarbeitung)

Was ist bei externen KI-Anbietern zu beachten?



Statusklärung

Prüfen ob eine Auftragsverarbeitung vorliegt



Auftragsverarbeitung

Wenn eine Auftragsverarbeitung vorliegt, muss eine Auftragsverarbeitungsvereinbarung (AVV) abgeschlossen werden



Datenübertragung in Drittstaaten

Besondere Risiken durch Drittstaaten

Internationale DatenverarbeitungIntegration

Viele Anbieter (z.B. OpenAI, Google Bard) verarbeiten Daten außerhalb der EU (z.B. USA).

Problematisch, wenn Drittstaaten kein angemessenes Datenschutzniveau bieten (siehe Schrems II).

Erforderliche Schutzmaßnahmen

Unternehmen müssen Schutzmaßnahmen ergreifen:

- Standardvertragsklauseln
- Transfer Impact Assessments
- Zusätzliche technische Sicherungen



Risiken bei öffentlich zugänglichen KI-Modellen

Keine sensiblen Eingaben ohne Freigabe



Datenspeicherung

Öffentliche KI-Tools (ChatGPT, Gemini) speichern oft Eingabedaten oder nutzen sie weiter.



Datenschutzrisiko

Keine vertraulichen oder personenbezogenen Daten ohne ausdrückliche Freigabe eingeben.



Interne Regelungen

Klar kommunizierte interne Regeln schützen vor unkontrolliertem Datenverlust.



Datensicherheit bei KI-Systemen (TOM)

Technische und organisatorische Maßnahmen

Integration in IT-Sicherheit

KI muss ins bestehende IT-Sicherheitskonzept integriert werden.

Pflichtmaßnahmen

Klare Zugriffsrechte, Verschlüsselung, Monitoring, Logging.

Kontinuierliche Prüfung

KI-Systeme regelmäßig prüfen und aktualisieren (Updates, Sicherheitsanalysen).

Risiko „Schatten-KI“ und Kontrollverlust

Warum „Schatten-KI“ gefährlich ist



Problem

Mitarbeitende nutzen eigenständig nicht freigegebene KI-Tools („Shadow AI“).



Risiken

Kontrollverlust über Daten, Datenschutzverletzungen, Sicherheitsrisiken.



Lösung 1

Klare interne Vorgaben und Schulungen zu erlaubten KI-Tools.



Lösung 2

Zentrale Freigabeprozesse, ggf. Whitelisting erlaubter Anwendungen.



Manipulierbarkeit von KI und Schutzmaßnahmen

Manipulation verhindern und Risiken senken

1

Manipulationsrisiken

KI ist anfällig für Manipulation (Prompt-Injection, fehlerhafte Trainingsdaten).

2

Mögliche Folgen

Falsche Empfehlungen, Sicherheitslücken, fehlerhafte Entscheidungen.

3

Schutzmaßnahmen

Trainingsdaten und Prompts auf Qualität prüfen. Klare Vorgaben zu Datenminimierung und Zweckbindung.
Permanente Überwachung und regelmäßige Tests auf Manipulierbarkeit.